

우수검사실 신임인증 심사점검표

개인정보 보호

가상인증원

이 책자는 데모용 가상 콘텐츠이며 실존 인증기관·심사문항과 무관한 무저작권 창작물입니다.

2027. 01

2027 년 개정판 변경내역 요약

(Summary of Changes)

개인정보 보호

아래 심사문항들은 본 개정판에 신규 도입, 주요 문항/설명 수정 또는 삭제된 문항들입니다.

• 신규

문항번호 사유

50.090.020 신규 문항

• 수정

문항번호 수정유형

50.010.010 설명 수정

50.040.020 배점 변경

• 삭제

문항번호 사유

50.020.030 문항 삭제

- **문항분류체계**

- 핵심문항 : C (Core standards)**

- 인증 유지에 결정적인 핵심 항목으로, 미충족 시 인증에 중대한 영향을 준다.

- 필요문항 : R (Required standards)**

- 적정 수준의 품질 확보를 위하여 갖추어야 하는 항목이다.

- 기본문항 : B (Basic standards)**

- 기본적으로 준수하여야 하는 항목으로 대부분의 문항이 이에 해당한다.

목 차

1. 관리체계 및 책임
2. 수집·이용 및 동의
3. 보유 및 파기
4. 접근통제 및 암호화
5. 물리적·기술적 보호조치
6. 처리위탁 관리
7. 유출사고 대응
8. 정보주체 권리 보장
9. 국외 이전

1. 관리체계 및 책임

문항 핵심C 50.010.010 개인정보 처리 업무를 총괄하는 개인정보 보호책임자를 지정하고, 그 성명과 연락처를 홈페이지 등에 공개하고 있는가?

배점

(3) 아니오

설명

- 개인정보 보호책임자 지정 문서와 공개 화면을 확인한다. 직무대행자를 지정한 경우 대행 근거와 지정 기간을 함께 확인한다.

문항 기본B 50.010.020 개인정보 처리방침을 수립하여 공개하고, 변경 시 변경 사실과 시행 시기를 공지하고 있는가?

배점

(2) 아니오

설명

- 처리방침에 처리 목적, 항목, 보유기간, 제3자 제공, 위탁에 관한 사항이 포함되어 있는지 확인한다.

문항 기본B 50.010.030 개인정보를 취급하는 임직원을 대상으로 연 1회 이상 개인정보 보호 교육을 실시하고 있는가?

배점

(2) 아니오

설명

- 교육 계획서, 실시 결과 보고서, 참석자 명단을 확인한다. 신규 임용자 기본 교육 실시 여부를 포함한다.

문항 필요R 50.010.040 개인정보 보호 지침의 이행 실태를 연 1회 이상 자체 점검하고, 미비점에 대한 개선 계획을 수립하고 있는가?

배점

(3) 아니오

설명

- 해당사항 없음

2. 수집·이용 및 동의

문항 핵심C 50.020.010 개인정보 수집 시 수집 목적, 수집 항목, 보유기간을 정보주체에게 알리고 적법한 동의를 받고 있는가?

배점

(5) 아니오

설명

- 동의서 양식에 고지 사항이 빠짐없이 포함되어 있는지 확인한다. 동의 거부 권리와 불이익 안내 문구를 함께 확인한다. 수집 목적이 변경된 경우 별도 동의를 받았는지도 점검 대상이다.

문항 기본B 50.020.020 만 14세 미만 아동의 개인정보를 처리하는 경우 법정대리인의 동의를 받고 있는가?

배점

(2) 아니오 해당없음

설명

- 아동의 개인정보를 처리하지 않는 기관은 해당없음으로 처리할 수 있다.

3. 보유 및 파기

문항 필요R 50.030.010 보유기간이 경과하거나 처리 목적이 달성된 개인정보를 지체 없이 파기하는 절차를 수립하여 이행하고 있는가?

배점

(3) 아니오

설명

- 파기 절차 문서와 최근 1년간의 파기 실적을 확인한다. 전자 파일은 복구할 수 없는 방법으로 삭제하였는지 확인한다.

문항 기본B 50.030.020 개인정보 파기 시 파기 일시, 대상, 방법을 파기대장에 기록하고 개인정보 보호책임자의 확인을 받고 있는가?

배점

(1) 아니오

설명

- 해당사항 없음

문항 기본B 50.030.030 가명정보를 처리하는 경우 원상 복원을 위한 추가 정보를 분리 보관하는 등 안전조치를 이행하고 있는가?

배점

(2.5) 아니오 해당없음

설명

- 가명정보를 처리하지 않는 기관은 해당없음으로 처리할 수 있다.

문항 기본B 50.030.040 개인정보파일별 보유기간을 정하여 대장으로 관리하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

4. 접근통제 및 암호화

문항 핵심C 50.040.010 개인정보 처리시스템에 대한 접근 권한을 업무상 필요한 최소한의 범위로 부여하고,

인사이동 시 지체 없이 변경·말소하고 있는가?

배점

(4) 아니오

설명

- 접근 권한의 부여, 변경, 말소 기록을 3년 이상 보관하고 있는지 확인한다.

문항 필요R 50.040.020 외부에서 개인정보 처리시스템에 접속할 때 안전한 인증수단을 적용하는 등 접근통제 조치를 하고 있는가?

배점

(4) 아니오

설명

- 해당사항 없음

문항 핵심C 50.040.030 고유식별정보와 비밀번호를 안전한 암호 알고리즘으로 암호화하여 저장하고 있는가?

배점

(4) 아니오

설명

- 비밀번호의 일방향 암호화 여부와 정보통신망 전송 구간의 암호화 여부를 확인한다.

문항 필요R 50.040.040 개인정보 처리시스템의 접속기록을 1년 이상 보관하고 월 1회 이상 점검하고 있는가?

배점

(3) 아니오

설명

- 접속기록을 위·변조 방지를 위하여 별도 저장장치에 백업하여 보관하는지 확인한다.

5. 물리적·기술적 보호조치

문항 기본B 50.050.010 악성프로그램 방지를 위한 백신 소프트웨어 등 보안 프로그램을 설치하고 최신 상태로 유지하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

문항 기본B 50.050.020 전산실, 자료보관실 등 개인정보 보관 장소에 대한 출입통제 절차를 수립하여 운영하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

문항 기본B 50.050.030 개인정보가 기록된 서면을 잠금장치가 있는 안전한 장소에 보관하고, 반출 시 관리대장에 기록하고 있는가?

배점

(1.5) 아니오

설명

- 해당사항 없음

6. 처리위탁 관리

문항 필요R 50.060.010 개인정보 처리 업무를 위탁하는 경우 안전조치에 관한 사항이 포함된 문서로 계약을 체결하고 있는가?

배점

(3) 아니오

설명

- 해당사항 없음

문항 기본B 50.060.020 수탁자가 개인정보를 안전하게 처리하는지 연 1회 이상 교육 및 점검을 실시하고 있는가?

배점

(2) 아니오

설명

- 점검 결과에 따른 시정 요구와 이행 확인 기록을 확인한다.

문항 기본B 50.060.030 위탁하는 업무의 내용과 수탁자를 홈페이지 등에 공개하고 있는가?

배점

(1) 아니오

설명

- 해당사항 없음

문항 기본B 50.060.040 수탁자가 위탁받은 업무를 재위탁하는 경우 사전 승인 절차를 운영하고 있는가?

배점

(1) 아니오 해당없음

설명

- 재위탁 사례가 없는 기관은 해당없음으로 처리할 수 있다.

7. 유출사고 대응

문항 핵심C 50.070.010 개인정보 유출사고에 대비한 대응 절차를 수립하고 담당자와 보고 체계를 정하고 있는가?

배점

(4) 아니오

설명

- 해당사항 없음

문항 필요R 50.070.020 개인정보 유출 시 정보주체에 대한 통지와 관계 기관 신고 절차를 갖추고 있는가?

배점

(3) 아니오

설명

- 통지 항목에 유출 항목, 유출 경위, 대응 조치가 포함되는지 확인한다.

문항 기본B 50.070.030 연 1회 이상 유출사고 대응 모의훈련을 실시하고 그 결과를 기록하고 있는가?

배점

(2) 아니오

설명

- 해당사항 없음

8. 정보주체 권리 보장

문항 필요R 50.080.010 정보주체의 열람, 정정, 삭제, 처리정지 요구를 처리하는 절차를 마련하고 기한 내에 처리하고 있는가?

배점

(3) 아니오

설명

- 권리 행사 요구 접수일부터 10일 이내에 조치 결과를 통지하는지 확인한다.

문항 기본B 50.080.020 법령에서 정하는 경우 개인정보 이용내역을 정보주체에게 주기적으로 통지하고 있는가?

배점

(1.5) 아니오 해당없음

설명

- 이용내역 통지 의무 대상이 아닌 기관은 해당없음으로 처리할 수 있다.

문항 기본B 50.080.030 영상정보처리기기 운영 시 안내판을 설치하고 운영·관리 방침을 수립하여 공개하고 있는가?

배점

(2) 아니오 해당없음

설명

- 영상정보처리기기를 운영하지 않는 기관은 해당없음으로 처리할 수 있다.

문항 기본B 50.080.040 개인정보 처리시스템을 신규로 도입하거나 변경할 때 개인정보 침해 위험을 사전에 검토하고 있는가?

배점

(2.5) 아니오

설명

- 해당사항 없음

9. 국외 이전

문항 필요R 50.090.010 개인정보의 국외 이전 여부를 정기적으로 파악하고, 이전 시 보호조치와 계약 사항을 점검하고 있는가?

배점

(3) 아니오

설명

- 2026년도 신규 문항이다. 국외 이전 현황 조사 결과와 점검 기록을 확인한다.

문항 기본B 50.090.020 개인정보를 국외로 이전하는 경우 이전받는 자, 이전 항목, 이전 목적을 정보주체에게 알리고 그 내역을 기록하여 관리하고 있는가?

배점

(2) 아니오 해당없음

설명

- 2027년도 신규 문항이다. 국외 이전이 없는 기관은 해당없음으로 처리할 수 있다.